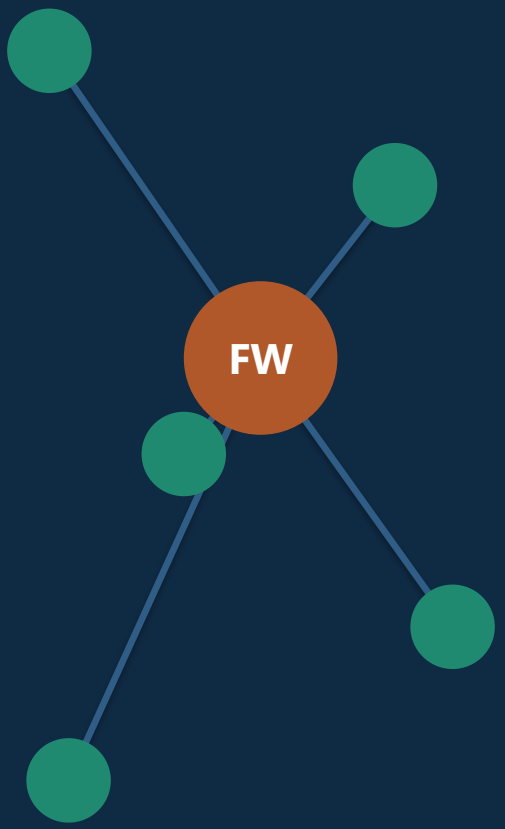
UNIVERSIDAD PRIVADA DE TACNA · INGENIERÍA DE SISTEMAS

Monitor de conexiones RDP en Windows

Diseño de la solución tecnológica · Unidad II

Traffic Analyzing Remote Desktop Connection Logs in Windows



Mattias Lupaca
Dorian Avendaño
Leonel Rivera
Piere Carrillo
Dana Franco
Fabiana Del Pino

Sistemas Operativos I · Docente: Dr. Renzo Alberto Taco Coayla

Ruta de la exposición: seis partes

1 Mattias

Problema y arquitectura

Por qué y cómo se organiza

2 Dorian

Infraestructura y red

Laptop, 4 VM, VLAN y firewall

3 Leonel

Fuentes y correlación

Eventos + flujos, regla de 20 s

4 Piere

Seguridad y respaldo

Riesgos, controles y 3-2-1

5 Dana

Reglas y alertas

Puntaje 0–100 explicable

6 Fabiana

Prototipo, plan y costos

Figma, Unidad III y S/ 489

Cada parte dura unos 3 minutos · las diapositivas llevan en la esquina quién expone

PARTE 1 · MATTIAS

El problema: red y registros por separado

- RDP va cifrado: de la red solo se ven IP, puertos, tiempos y volumen
- Windows dice quién entró y si falló, pero no por qué conexión
- Unir ambos a mano es lento y propenso a error

6:16

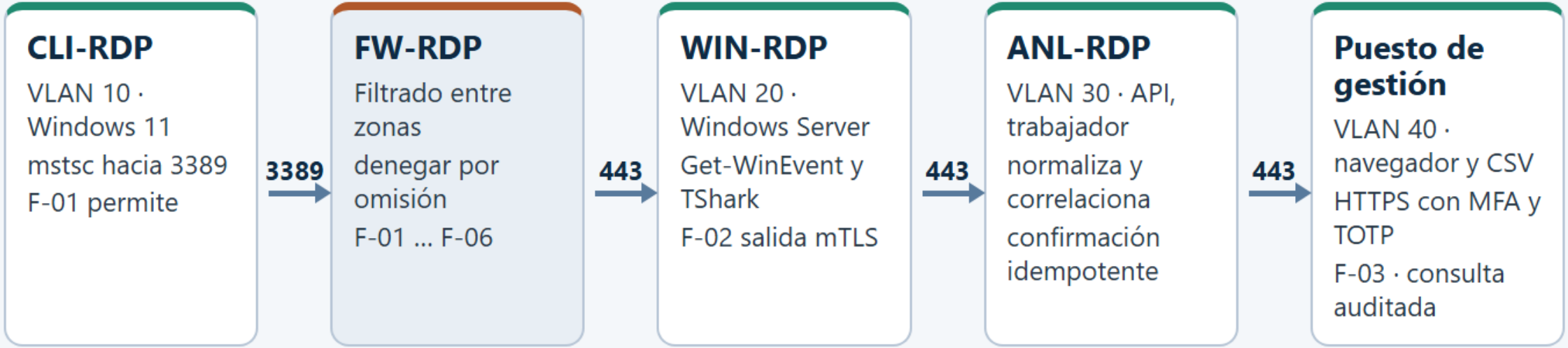
mediana de emparejar a mano un evento con su flujo (4 personas) · solo 2 de 4 dieron el estado correcto

Objetivo

Un tablero que correlaciona flujo + evento, explica el riesgo (0–100) y conserva la evidencia

PARTE 1 · MATTIAS

Arquitectura: cuatro etapas, una sola ruta



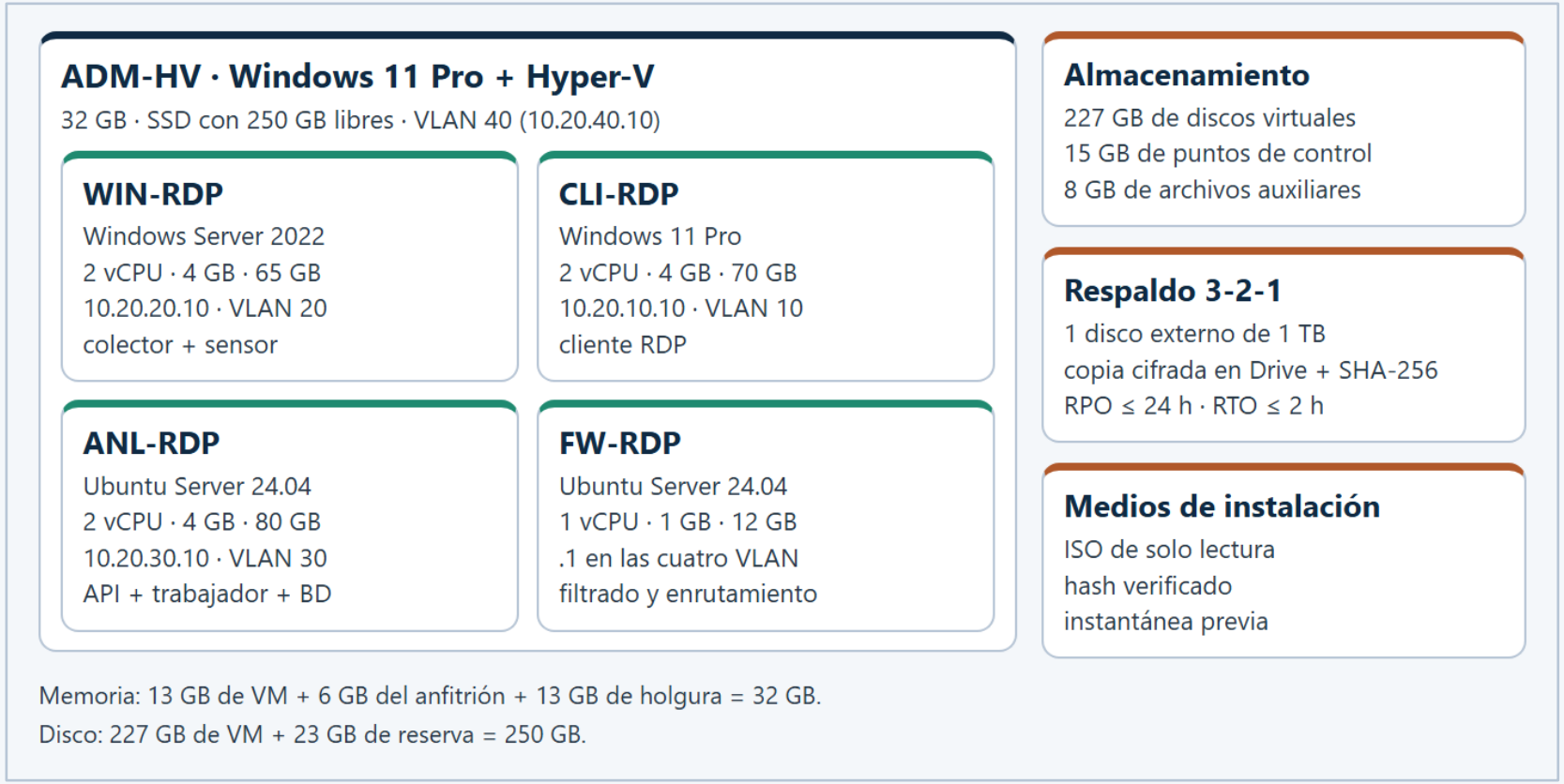
1 Adquisición → 2 Transporte → 3 Procesamiento → 4 Presentación
Cada registro conserva su evidence_id y la versión de regla

PostgreSQL escucha solo en 127.0.0.1 y la cola persistente vive en ANL-RDP: el tablero nunca consulta la base directamente.
La ruta es unidireccional. El cliente inicia RDP y el colector inicia la ingesta; entre zonas no circula otro tráfico que el de F-05.

Decisiones: PostgreSQL en vez de SIEM · reglas en vez de aprendizaje automático · sondeo cada 5 s (ADR-01 a 03)

PARTE 2 · DORIAN

Infraestructura: cuatro VM en una laptop



ThinkPad X1 Carbon Gen 10 · Core i7-1280P · Windows 11 Pro + Hyper-V

32 GB
RAM · 13 GB para las VM

4 VM
servidor, cliente, análisis y firewall

250 GB
de disco como máximo (279 libres)

Red: 4 VLAN y un firewall que niega todo

PARTE 2 · DORIAN



Reglas del firewall

- F-01 RDP 3389 solo desde el cliente
- F-02 ingesta por 443 (mTLS)
- F-03 tablero 443 y SSH solo desde VLAN 40
- F-04 NTP 123 · F-05 retorno establecido
- F-06 denegar y registrar todo lo demás

Sin salida a Internet · sin NAT entre zonas

PARTE 3 · LEONEL

Dos fuentes que solas no alcanzan

Red · TShark / Npcap

- IP, puertos, bytes y tiempos
- Flujos TCP hacia el puerto 3389
- No sabe quién ni si autenticó

+

Windows · Get-WinEvent

- 4624 tipo 10, 4625, 4778/4779, 4688
- Sesión: inicio, desconexión y reconexión
- No sabe por qué flujo entró

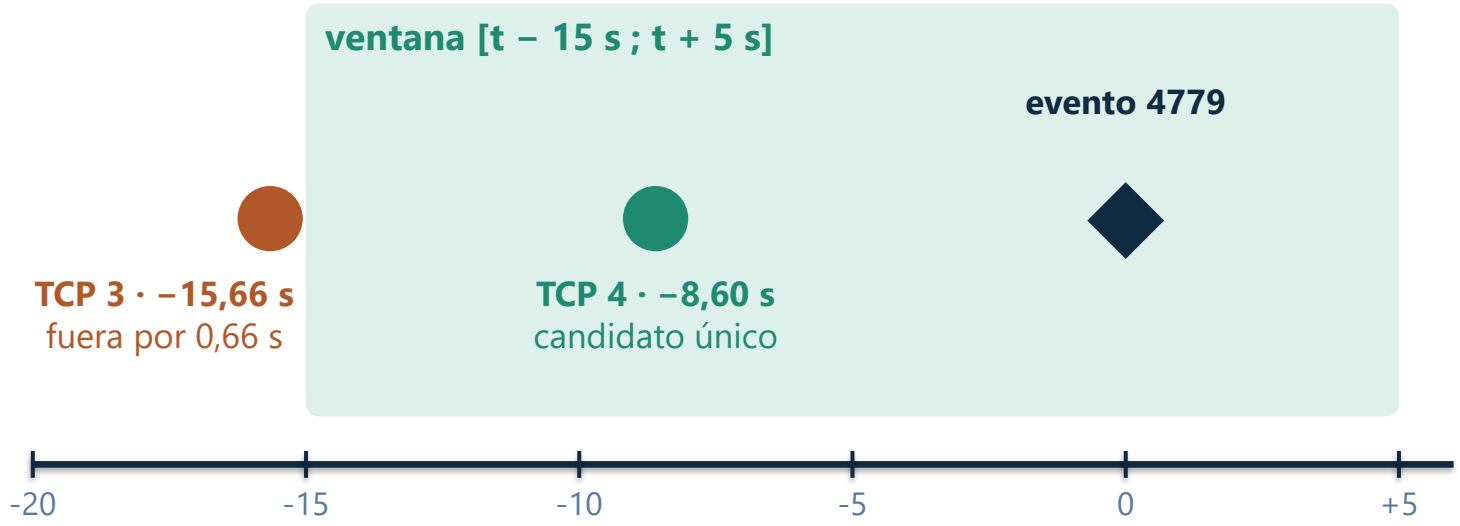
Regla de correlación

mismo origen y flujo iniciado entre t − 15 s y t + 5 s

CONFIRMADO | PENDIENTE | SIN ASOCIACIÓN

PARTE 3 · LEONEL

Prueba con la captura real



Los flujos 0, 1 y 2 están a −268, −152 y −109 s: quedan fuera (segundos en el eje)

PENDIENTE

un candidato, pero el 4779 no trae puerto ni hay un 4624 tipo 10

Qué se probó

- 1 evento y 5 flujos reales
- Hashes SHA-256 verificados
- 3 casos sintéticos: los 3 estados
- Mismo resultado que el informe (2.1)

Seguridad: zonas y controles

PARTE 4 · PIERE

Zona cliente
VLAN 10 · confianza baja

Cliente autorizado
NLA y certificado TLS
Origen fijado en F-01

Amenazas asociadas
S-01 S-02

→

Zona Windows
VLAN 20 · confianza media

NLA + TLS de laboratorio
Auditoría de inicio y proceso
Lotes firmados con mTLS

Amenazas asociadas
S-03 S-10

→

Zona analítica
VLAN 30 · confianza media

Argon2id + TOTP
Roles y mínimo privilegio
Bitácora y SHA-256

Amenazas asociadas
S-04 S-06 S-08

→

Zona de gestión
VLAN 40 · confianza alta

MFA para el tablero
CSRF y cookies seguras
Aprobación de cambios

Amenazas asociadas
S-05 S-07 S-09

Perímetro: FW-RDP deniega por omisión (F-06) y registra los rechazos. Cada zona solo alcanza la siguiente por la regla declarada en la Tabla 16.

Controles transversales: sincronización NTP con deriva > 2 s marcada como degradada · respaldo 3-2-1 fuera de la base operativa · auditoría de accesos y exportaciones.

El residuo se acepta solo si la prueba correspondiente lo confirma; el Anexo K documenta por riesgo el control, la exposición que subsiste y la prueba que puede refutarla.

Cómo lo cubrimos

- 12 riesgos con probabilidad × impacto (NIST SP 800-30)
- Controles mapeados a CSF 2.0 e ISO 27001
- Tablero con MFA (TOTP) y roles de mínimo privilegio
- Cada riesgo con su prueba: CP-06, CP-07, CP-09

PARTE 4 · PIERE

Respaldo 3-2-1, ya verificado

1

Base operativa

PostgreSQL en el SSD de la laptop

2

Disco externo de 1 TB

Copia cifrada diaria a las 02:00 · 7 días

3

Google Drive

Copia cifrada y manifiesto SHA-256 · probada el 11/11

≤ 24 h

RPO por construcción: copia diaria

1,08 s

restaurar y verificar 30 000 eventos (ensayo preliminar)

SHA-256

el archivo de prueba subido a Drive coincide

El RTO ≤ 2 h se mide oficialmente en CP-07 sobre la VM ANL-RDP (el ensayo se hizo en otra PC).

Reglas explicables: 7 señales, 0–100

R-01	≥ 5 fallos en 5 min (mismo origen)	25 pts
R-02	Éxito tras ≥ 5 fallos	30 pts
R-03	IP nueva en 14 días	15 pts
R-04	Fuera del horario autorizado	10 pts
R-05	Privilegios (4672) al iniciar	15 pts
R-06	≥ 3 IP distintas en 15 min	15 pts
R-07	≥ 8 fallos a ≥ 5 cuentas (spraying)	55 pts

R-01 + R-02 se limitan a 50 puntos juntas · el total máximo es 100

Severidad

Crítica
75–100 puntos

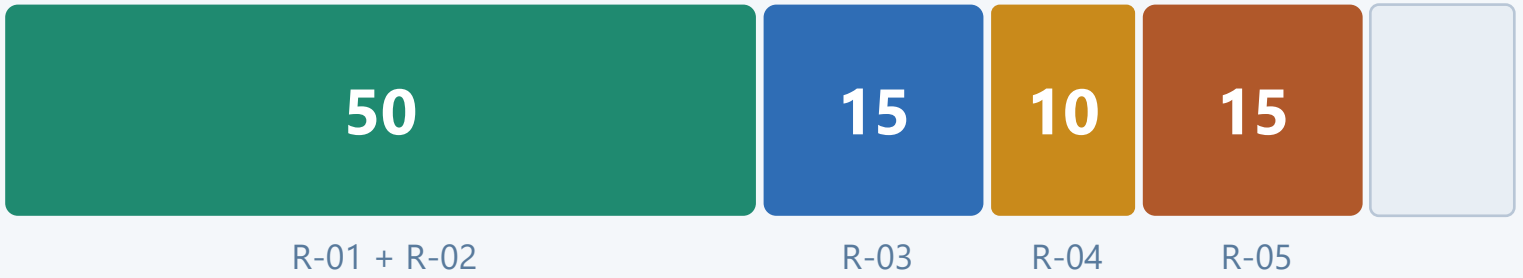
Alta
50–74 puntos

Media
25–49 puntos

Baja
0–24 puntos

Caso AL-018: 90/100, severidad crítica

La cuenta lab-07 entra tras cinco fallos, desde una IP nueva y fuera de horario



50 + 15 + 10 + 15 = 90 de 100

7 de 7
casos sintéticos reproducen el puntaje esperado

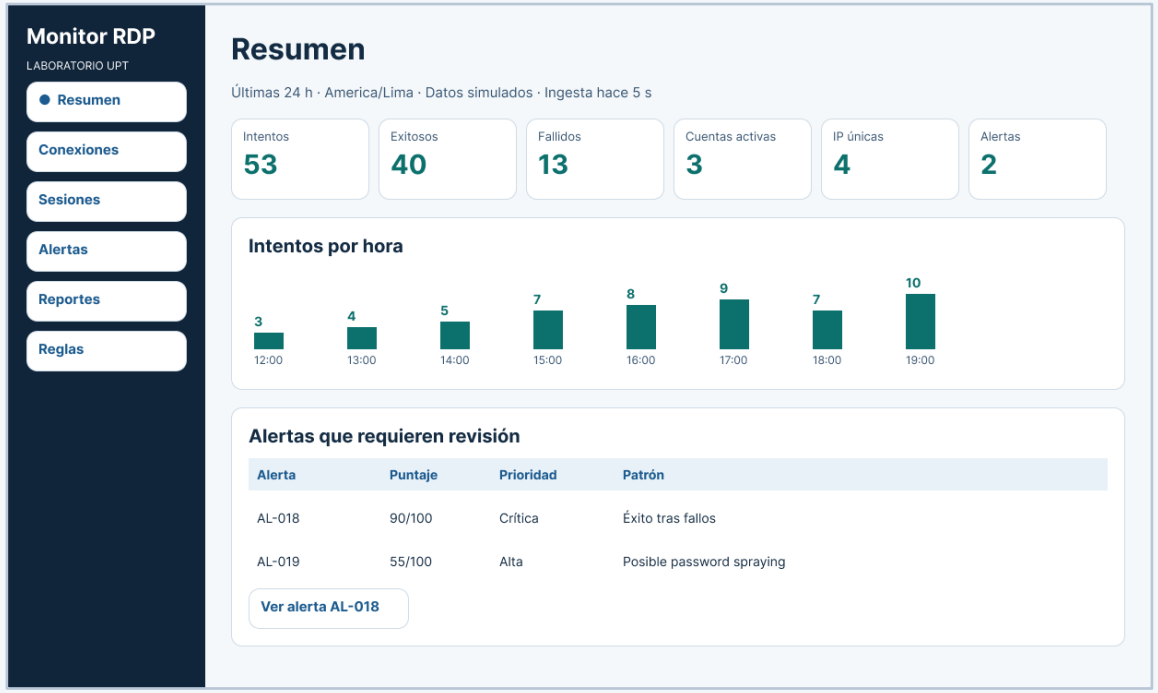
≥ 90 %
detección esperada en Unidad III (20 + 20 escenarios)

Por qué es explicable

- El tablero muestra qué reglas sumaron y con qué evidencia
- La versión de reglas queda registrada
- El analista decide: no hay contención automática
- R-06 y R-07 se prueban con registros sintéticos de varios orígenes

Prototipo en Figma: tres casos

PARTE 6 · FABIANA



Resumen del laboratorio



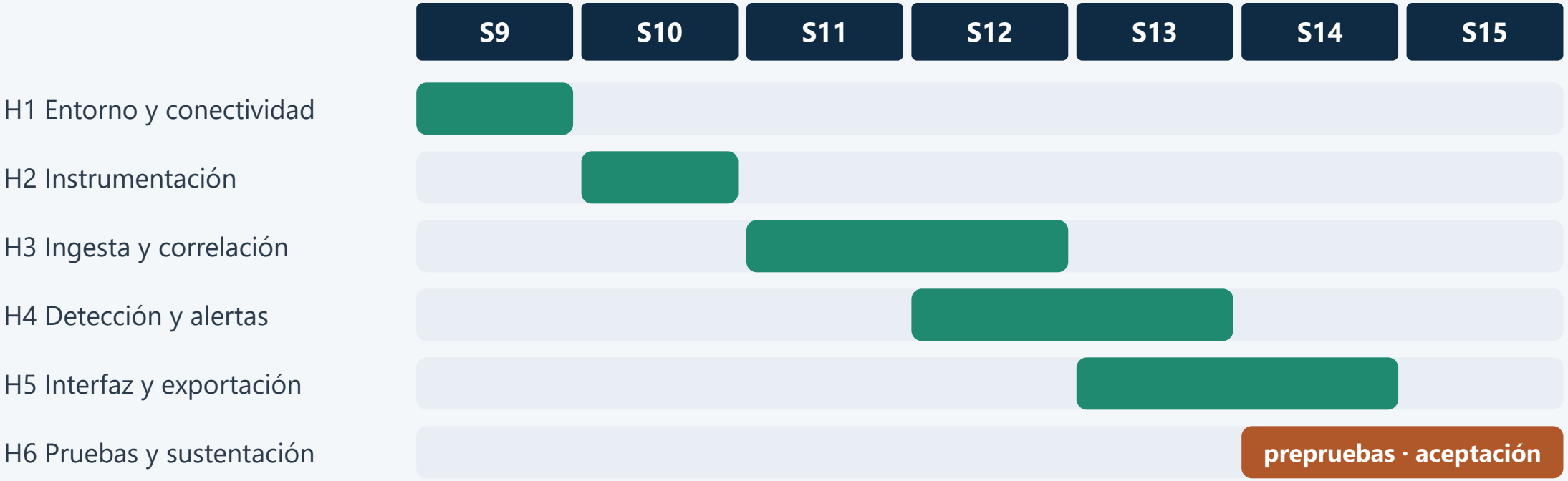
Detalle de la alerta AL-018

CD-01 · AL-018 · 90/100 | **CD-02 · acceso normal · 0/100** | **CD-03 · correlación ambigua · pendiente**

Datos simulados · el tablero funcional se implementa en la Unidad III · figma.com/proto/h8yUohZU6NVHWTLkb2AYWn

PARTE 6 · FABIANA

Unidad III: siete semanas y S/ 489,21



S/ 489,21
costo adicional a 12 meses

9 pruebas
CP-01 a CP-09 · 5 en vivo, 4 con acta

Sin comprar licencia
Windows Server en evaluación de 180 días

Todo lo diseñado se implementa en la Unidad III

Entregamos

- 4 diagramas y una API de 12 puntos
- 4 VM, 4 VLAN y 6 reglas de firewall
- 7 reglas y 12 riesgos con su prueba
- Prototipo, correlación real y respaldo

Enlaces

- GitHub: PiereC8/traffic-analyzing-rdp-windows
- Drive: carpeta del proyecto
- Figma: prototipo con los 3 casos

¿Preguntas?